(ISC)²® | SECURITY CONGRESS

EMPOWER

a Safer, More Secure Cyber World

Congress.isc2.org | #ISC2Congress

Emerging threats against cloud application identities and what you should do about it

Etan Basseri

Bailey Bercik

North Star

Prevent unauthorized access to a resource by an application or service

Agenda

What is risk?

How to detect

How to contain, mitigate and remediate

How to protect

Microsoft warns about this phishing attack that wants to read your emails

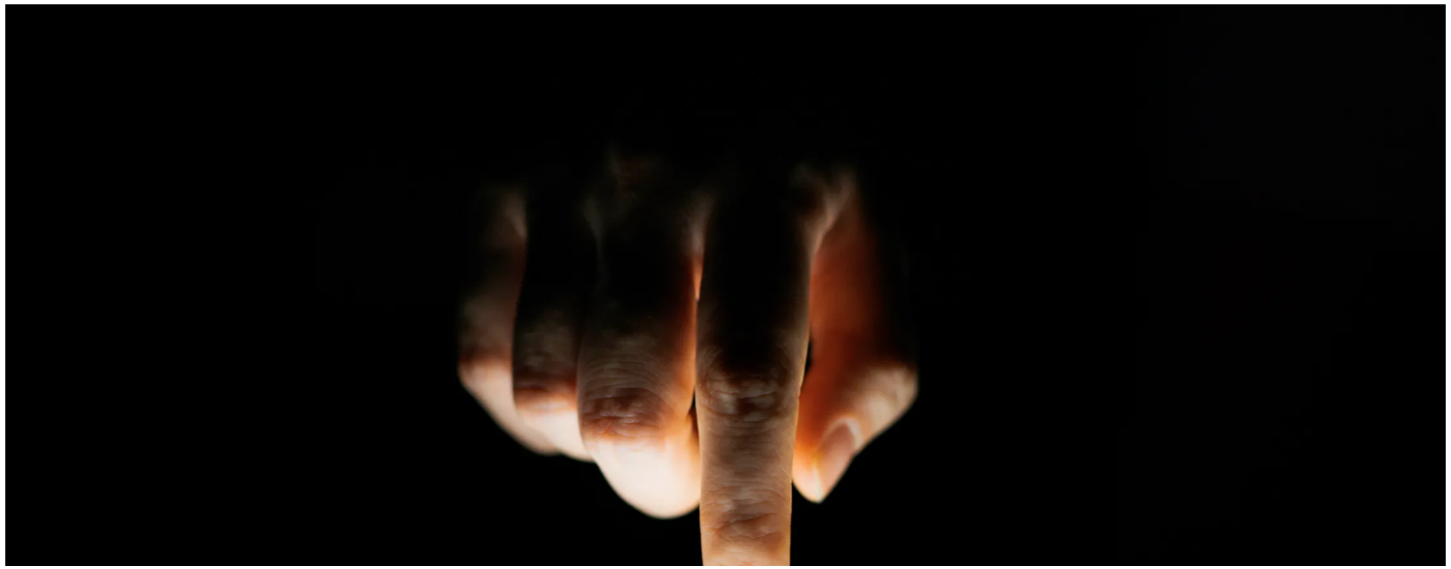
Attackers have targeted hundreds of organisations, says Microsoft security.

Written by **Liam Tung,** Contributing Writer on Jan. 25, 2022

LILY HAY NEWMAN SECURITY SEP 1, 2022 6:00 AM

Careless Errors in Hundreds of Apps Could Expose Troves of Data

Researchers found that mobile applications contain keys that could provide access to both user information and private files from unconnected apps.



(ISC)2® | SECURITYCONGRESS Congress.isc2.org | #ISC2Congress

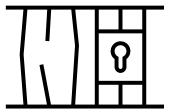
Efficient 'MagicWeb' Malware Subverts AD FS Authentication, Microsoft Warns

The Russia-backed Nobelium APT has pioneered a post-exploitation tool allowing attackers to authenticate as any user.

Dark Reading Staff
Dark Reading

August 24, 2022

Application identity threats



Compromised

Legitimate app that has been hijacked

Malicious

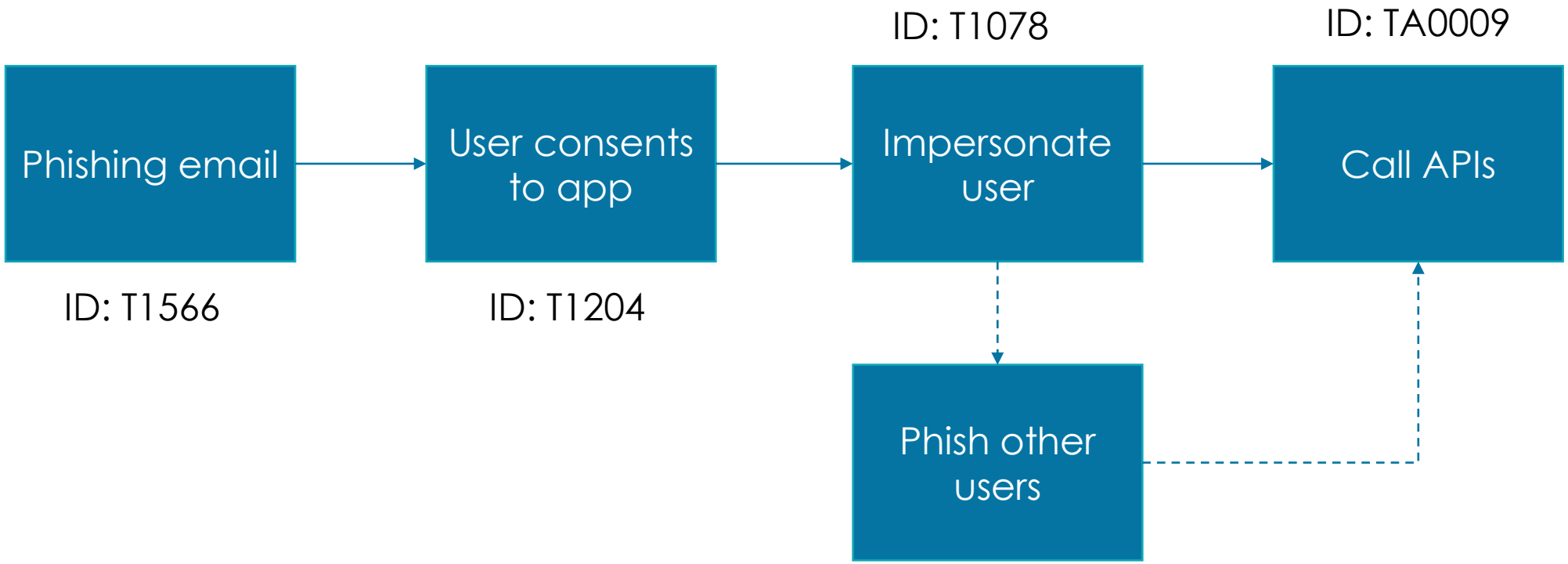
Created by an attacker for bad purposes

Misconfigured

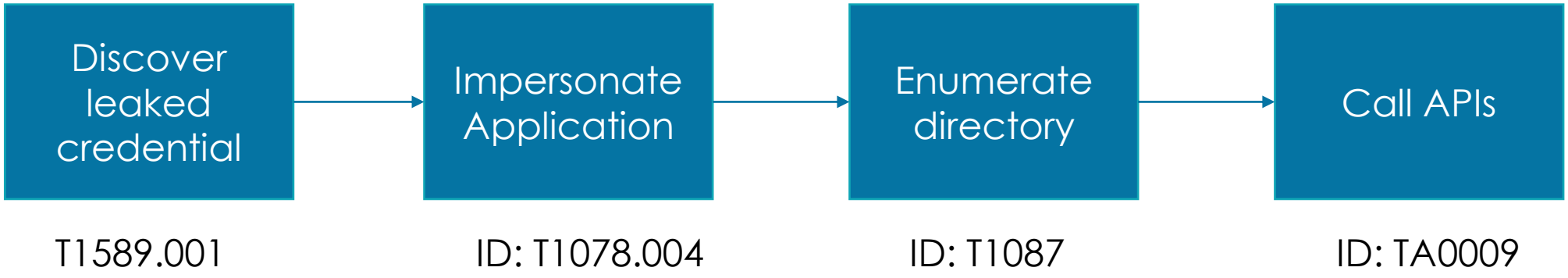
Insecure configuration in/outside your identity provider that makes it susceptible to compromise

Attack graph – Compromised app

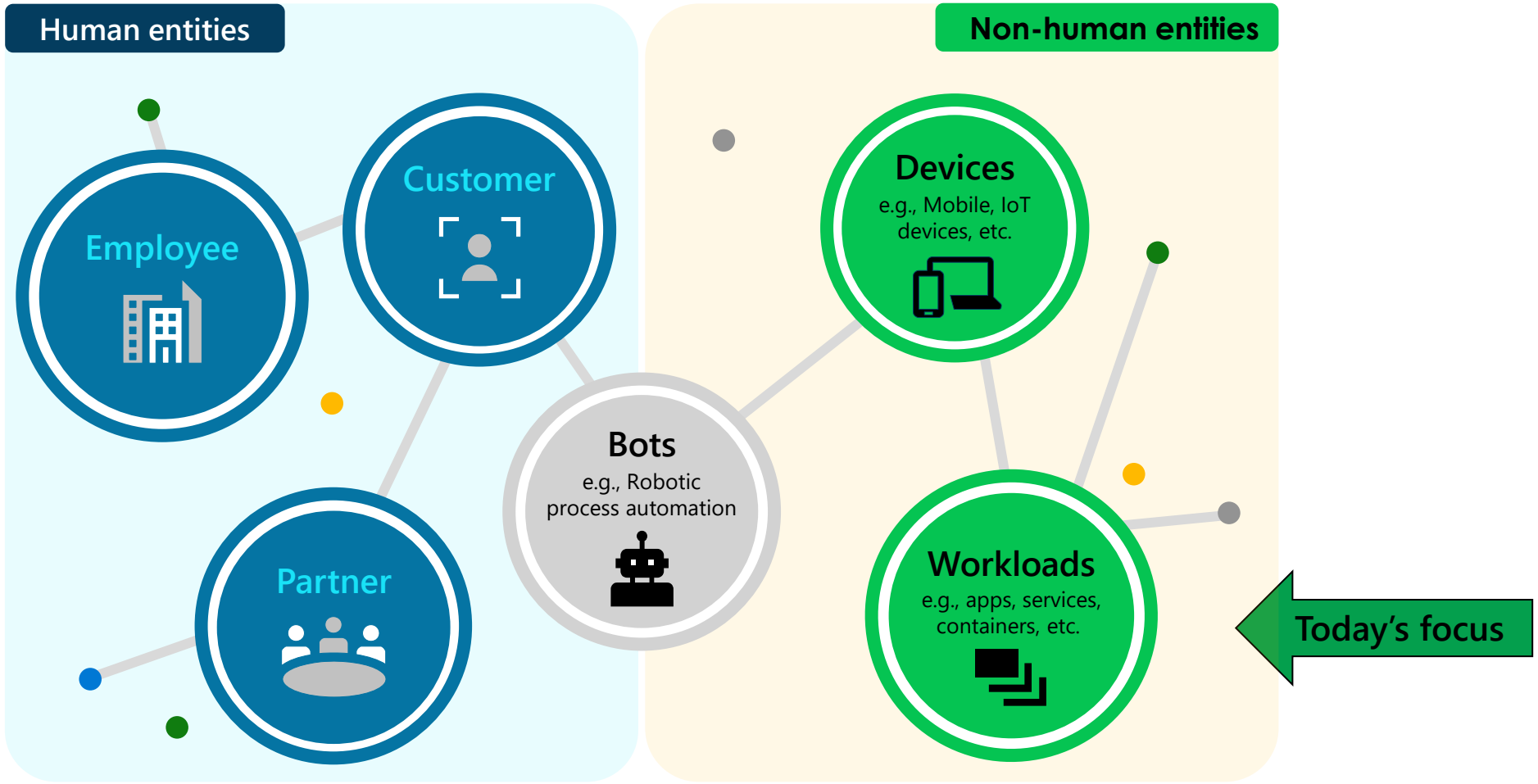
Attack graph – Malicious app



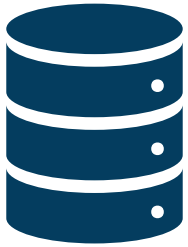
Attack graph – Misconfigured app



What are Workload Identities?



Examples of service-to-service scenarios
(confidential client flow)



Data Backup Services

CRM Systems

Security Software

The “Street Light” Effect

What do we focus on?

What needs increased focus?

What new partnerships do we need?

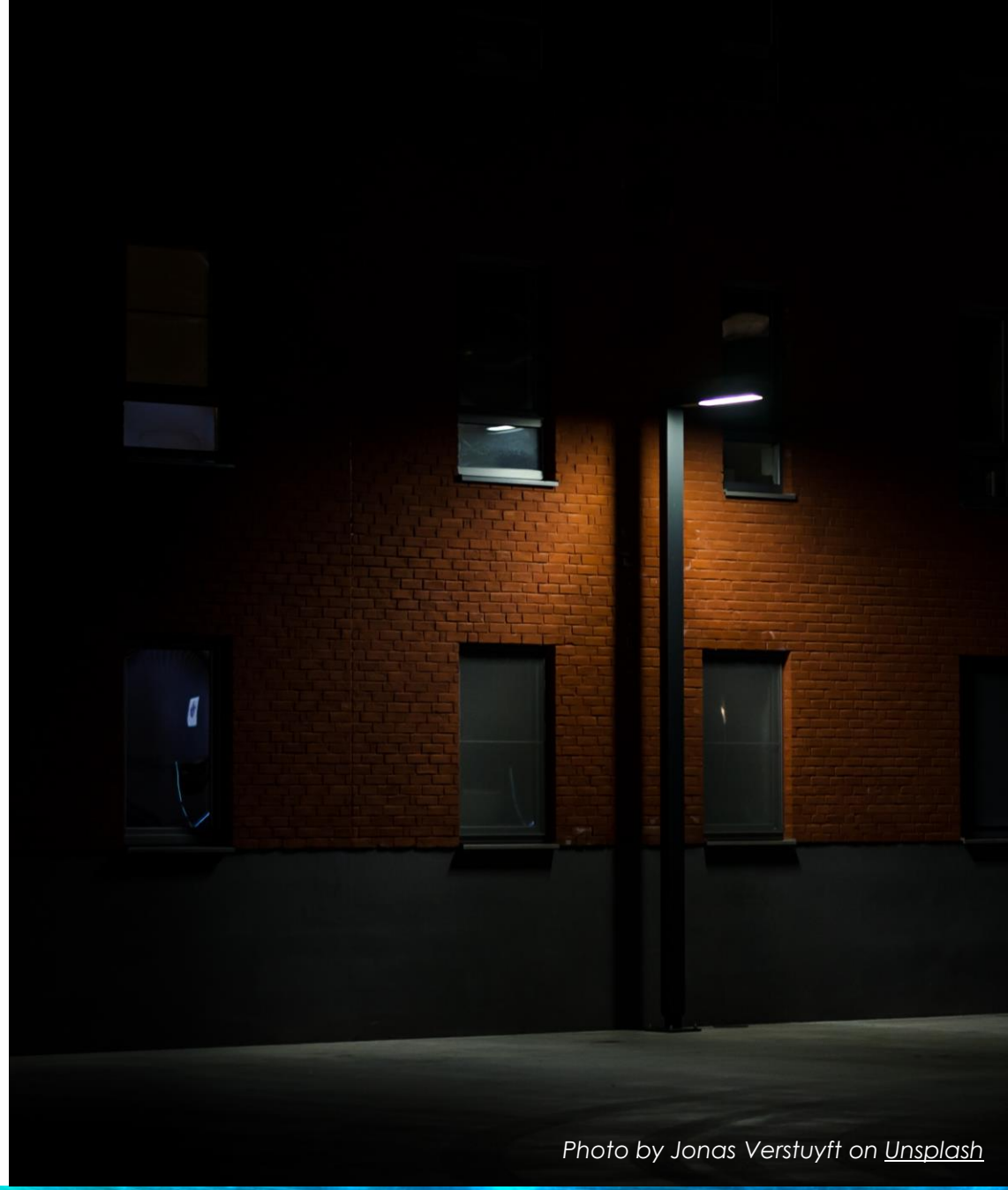


Photo by Jonas Verstuyft on Unsplash

Application Threats

- **26 million** user creds stolen by malicious applications from 2018-2020
- **4.9:** Average number of incidents involving theft/misuse of a key or certificate an organization is likely to experience in a 24-month period
- **4k+** unique app identities leaked in Github in 2022

Parachute, 2022 Cyber Attack Statistics, Data and Trends
Ponemon Institute, State of Machine Identity Management 2021
Microsoft Identity & Network Access Division

Agenda

What is risk?

How to detect

How to contain, mitigate and remediate

How to protect

Sign-in logs

Location

IP address

ASN

Country

Frequency

Most have a predictable pattern

User agent

Anything unexpected or violates security policy

Credential type

Anything unexpected or violates security policy

Resource

Should this identity be accessing this resource?

Audit logs

Permissions

High privilege grant

End user granting applications consent

End user consent blocked on risk level

In Azure – service principal assigned to an Azure AD or Azure RBAC role; changes to Azure Key Vault

Time/process

Changes made outside of normal business processes and schedules

Credential type

Unauthorized changes or types

Configuration

Universal resource identifier (URI) changed or non-standard

Changes to application owners

Logout URLs modified

Secret scanning

Your own tool

Use on-prem / cloud

Customizable

Some OSS options

Vendor tools

Most are cloud-based

Scalable

More current (secret format)

More recall (scans entire service not just your repos)

More precision (some will tell you if the secret is still valid)

Microsoft Entra admin center

maya@woodgrove.ms
WOODGROVE (WOODGROVE.MS)

- Home
- Azure Active Directory
  - Overview
  - Users
  - Groups
  - Devices
  - Applications
  - Protect & secure
    - Conditional Access
    - Identity Protection
    - Authentication methods
    - Password reset
    - Custom attributes
    - Risky activities
  - Identity Governance
  - External Identities
  - Show more
- Permissions Management
- Verified ID
- Learn & support

Identity Protection | Overview

Search

- Overview
- Diagnose and solve problems

Protect

- User risk policy
- Sign-in risk policy
- Multifactor authentication registration policy

Report

- Risky users
- Risky workload identities (preview)
- Risky sign-ins
- Risk detections

Notify

- Users at risk detected alerts
- Weekly digest

Troubleshooting + Support

- Virtual assistant (Preview)
- Troubleshoot
- New support request

Agenda

What is risk?
How to detect
How to contain, mitigate and remediate
How to protect

Incident Response Basics

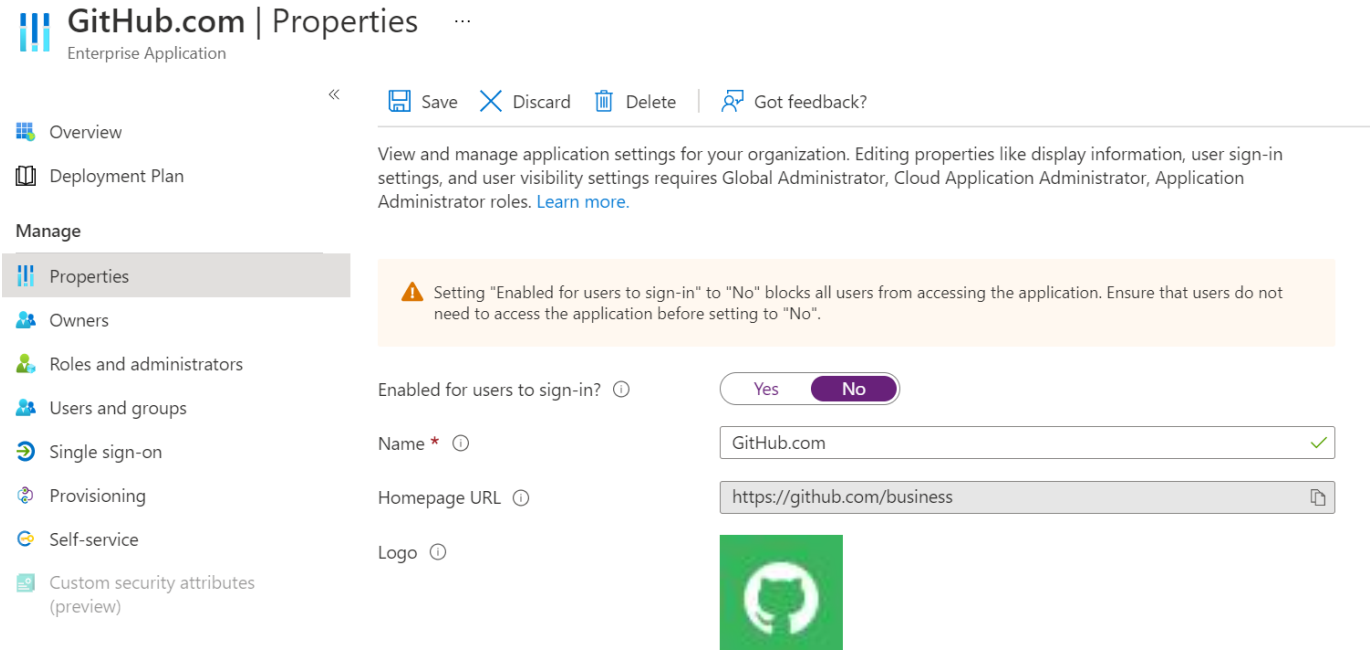
- Stay calm and do no harm
- Involve your legal team
- Be careful when sharing information publicly
- Get help when needed

Containment

Disable compromised application

- If admin creds are compromised, coordinate with eviction

Weigh impact of deletion or key rolling



Microsoft Entra admin center

maya@woodgrove.ms
WOODGROVE (WOODGROVE.MS)

- Home
- Azure Active Directory
  - Overview
  - Users
  - Groups
  - Devices
  - Applications
  - Protect & secure
    - Conditional Access
    - Identity Protection
    - Authentication methods
    - Password reset
    - Custom attributes
    - Risky activities
  - Identity Governance
  - External Identities
  - Show more
- Permissions Management
- Verified ID
- Learn & support

Conditional Access | Policies

Azure Active Directory

- Overview (Preview)
- Policies
- Insights and reporting
- Diagnose and solve problems

Manage

- Named locations
- Custom controls (Preview)
- Terms of use
- VPN connectivity
- Authentication context (Preview)
- Classic policies

Monitoring

- Sign-in logs
- Audit logs

Troubleshooting + Support

- Virtual assistant (Preview)
- New support request

New policy | New policy from template (Preview) | What If | Refresh | Got feedback?

Search policies | Add filters

53 out of 53 policies found

Policy Name	State	Creation Date	Modified Date
CA01 - MFA - All Apps - All Users - Do Not Change - Policy is monitored	On		9/12/2022, 3:16:01 AM
CA02 - Restrict - Security Apps - NOAM Offices	On		4/21/2022, 6:37:25 AM
CA03- Require Compliant Device - Register Security Information	On		9/2/2022, 2:42:55 PM
CA04 - Block Sensitive Apps from High sign-in risk users	On		7/27/2022, 3:33:04 PM
CA06 - All User - Block Legacy Auth	On		9/12/2022, 5:11:43 PM
CAX - TOU - All Woodgrove (and Guest) Users	On		4/10/2022, 2:01:13 PM
CA08 - MCAS Session Control - All Users	On		8/16/2022, 3:48:54 PM
CA09 - All Apps - Allow only Trusted Locations	On		1/14/2022, 11:05:59 AM
CA10 - Require MFA for VPN Access	On		9/18/2020, 11:58:52 AM
SEC01 - Require SecOps and DevOps Device - Restrcited Apps	On	11/20/2020, 11:20:32 ...	3/13/2021, 5:34:38 PM
CA11 - TOU - Partner Orgs	On	12/16/2020, 1:09:44 PM	3/4/2021, 6:32:42 PM
RO - Require Compliant device for all users all apps	Report-only	2/4/2021, 6:48:28 PM	3/13/2021, 5:32:29 PM
RO - Require MFA for medium risk user activating roles	Report-only	2/5/2021, 12:46:40 PM	3/23/2021, 5:47:29 PM
CA12 - All Admins TOU - Reminder	On	4/7/2021, 8:26:32 AM	8/18/2022, 1:59:08 PM
CA13 - Woodgrove Compliant device - Auth Context	On	8/3/2021, 11:47:20 AM	8/19/2022, 9:38:55 AM
CAX - Secure Admin Workstations - Project TNT Required	On	2/1/2022, 10:14:21 AM	2/2/2022, 11:34:20 AM
CA12 - Silverfort MFA - On-prem	On	2/3/2022, 2:13:02 PM	6/15/2022, 5:31:31 PM
CA15 - TOU Security Reminder	On	2/17/2022, 8:52:10 PM	2/24/2022, 12:59:38 PM
RO - Workload ID Block on risk, report-only	Report-only	3/1/2022, 11:18:06 PM	8/24/2022, 1:26:12 PM
CA16 - Require Partners Compliant Devices	On	3/10/2022, 4:41:44 PM	
CA17 - Require Compliant Device - Social Media Apps	On	4/6/2022, 3:47:22 PM	8/24/2022, 1:26:46 PM
CA18 - Cloud PC - Require Compliant	On	4/22/2022, 2:59:59 PM	8/24/2022, 1:30:29 PM
RO - Block - MFA Regirstion non-compliant devices	Report-only	5/4/2022, 2:29:52 PM	8/24/2022, 1:30:43 PM
CA19 - Private Link	On	5/15/2022, 4:02:03 PM	8/24/2022, 1:31:39 PM

Recovery

Remediate service principals

Remediate affected service principal resources

Disable or delete malicious apps

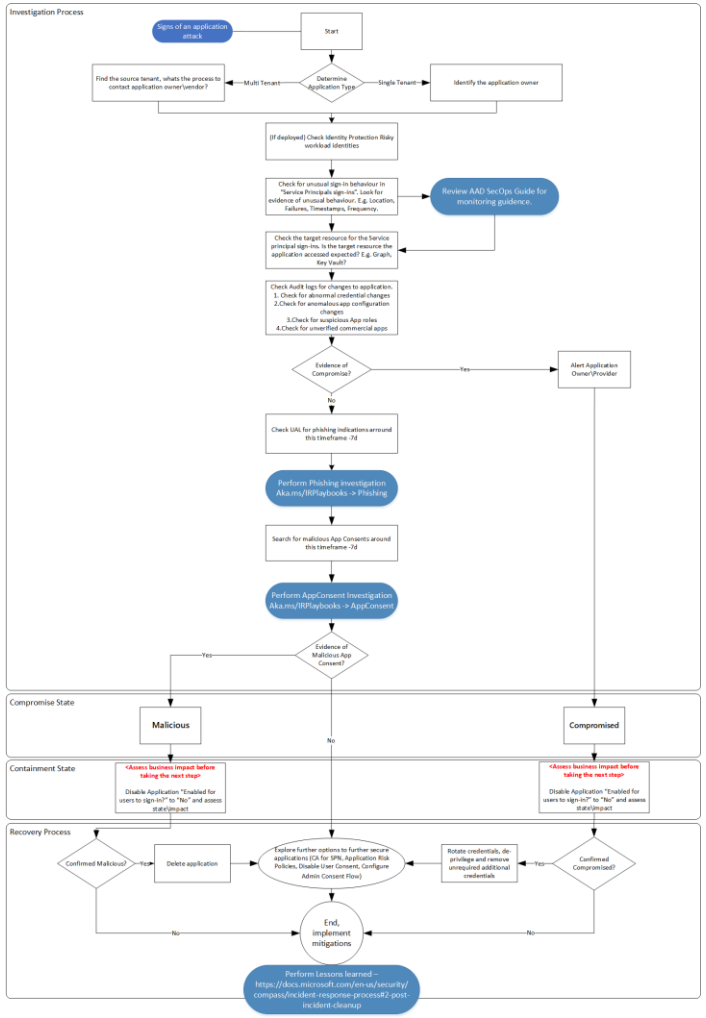
Implement Identity Protection for workload identities

aka.ms/IRPlaybooks

Detailed walkthrough at above link

Investigation process

- Whether an app is malicious or compromised
- Containment and assessing business impact
- Recovery process



Agenda

What is risk?
How to detect
How to contain, mitigate and remediate
How to protect

Treat workload identities like user accounts

Good security principles:

- Use strong credentials
- Least privilege
- Lifecycle management
- Monitor anomalies

Strong Credentials

Users

Use modern password guidance

- Discourage weak, easy to guess passwords
- Avoid arbitrary password rules that encourage patterns
- Monitor for leaked credentials

Leverage FIDO2 keys or other passwordless methods

Workload identities

Use X509 certs or managed identities instead of client secrets

Monitor applications to identify those with long credential expiration times

Replace long-lived credentials with credentials that have a short life span

Ensure that credentials don't get committed in code repositories and are stored securely

Least Privilege

Users

Assign admin roles only necessary permissions

Limit admin roles whenever possible

Use just-in-time (JIT) elevation and just-enough-administration (JEA)

Workload identities

Investigate application permissions and ensure they're truly needed

Identify existing applications with highly privileged permissions

Consider limiting end user consent

Analyze when end user consent is blocked

Lifecycle Management

Users

Clean up stale accounts

Recertify access for the accounts

Workload identities

Clean up stale apps and credentials

Recertify access for the accounts

Monitor apps with high permissions

Lower application permissions

Example: If your app only needs to read mail, lower permission from *Mail.ReadWrite.All* to *Mail.Read.All*

Monitor Anomalies

Users

Unfamiliar locations

New devices

Actions taken outside of typical working hours

Accessing unusual files

Workload identities

Universal resource identifier (URI) changed or non-standard

Changes to application owners

Logout URLs modified

Unauthorized changes to credentials

Home

Azure Active Directory
Overview
Users
Groups
Devices
Applications
Protect & secure
Conditional Access
Identity Protection
Authentication methods
Password reset
Custom attributes
Risky activities
Identity Governance
Entitlement management
Access reviews
Privileged Identity Management
External Identities
Show more

Learn & support

Privileged Identity Management | Quick start

Privileged Identity Management

Quick start

Tasks
My roles
My requests
Approve requests
Review access

Manage
Azure AD roles
Privileged access groups (Preview)
Azure resources

Activity
My audit history

Troubleshooting + Support
Troubleshoot
New support request

You are using the updated Privileged Identity Management experience for Azure AD roles. →

What's new | Get started

Manage your privileged access

Use Privileged Identity Management to manage the lifecycle of role assignments, enforce just-in-time access policy, and discover who has what roles. Learn more

Manage access

Users with excessive access are vulnerable in the event of account compromise. Ensure your organization manages to least privilege by periodically reviewing, renewing, or extending access to resources.

Manage

Activate just in time

Reduce the potential for lateral movement in the event of account compromise by eliminating persistent access to privileged roles and resources. Enforce just in time access to critical roles with PIM.

Activate

Discover and monitor

It is common for access to critical resources to go undetected. Ensure you know who has access to what, and receive notifications when new assignments are granted to accounts in your organization.

Discover

Go-Do's

1. Identify your app owners
2. Security operations guidance
   aka.ms/AzureADSecOps
3. Incident response guidance
   aka.ms/IRPlaybooks

Any Questions?

Deck available at aka.ms/SecurityCongress2022Deck

Demo